
POLÍTICA DE SEGURANÇA DA INFORMAÇÃO

Código:
POL-01

Versão:
1.0

Data de Emissão:
10/11/2025

Público-Alvo:
Público Interno e Externo

Aprovação:
Presidência

1 Introdução

Em uma sociedade caracterizada por uma crescente complexidade das ameaças digitais, organizações de todos os setores enfrentam riscos provenientes de ataques cibernéticos sofisticados, vazamentos de dados, engenharia social e falhas internas de segurança que podem comprometer não apenas a confidencialidade, a integridade e a disponibilidade das informações, mas também a continuidade operacional e a reputação institucional.

Neste contexto, a Sentinela Controladoria assume a proteção da informação como atividade essencial. Qualquer incidente de segurança afeta não apenas os resultados operacionais da organização, mas também a confiança de seus clientes e parceiros. A adoção de uma Política de Segurança da Informação (PSI) formal visa estabelecer diretrizes, responsabilidades e controles que assegurem a integridade, disponibilidade e confidencialidade das informações tratadas pela Sentinela, fortalecendo seu compromisso com a segurança digital e a conformidade regulatória.

2 Objetivo

Esta PSI tem como finalidade preservar a confidencialidade, a integridade e a disponibilidade das informações, assegurando que os dados corporativos e de clientes sejam tratados de forma ética, segura e em conformidade com legislações e normas aplicáveis e fortalecer a cultura organizacional de proteção de dados. Esta política é formalmente endossada e mantida pela alta administração da Sentinela Controladoria, seu cumprimento é obrigatório a todos os funcionários, independentemente de cargo ou vínculo contratual. Cada membro da organização tem o dever de zelar pela observância das diretrizes aqui definidas.

3 Definições

Para garantir a compreensão dos conceitos empregados nesta Política de Segurança da Informação, apresentam-se abaixo as definições de termos técnicos utilizados ao longo do documento.

3.1 Ativos Informacionais

Conjunto de dados, sistemas, documentos, equipamentos, softwares e demais recursos que possuem valor para a organização e cuja proteção é essencial para a continuidade dos negócios.

3.2 Confidencialidade

Princípio da segurança da informação que assegura que o acesso às informações seja restrito apenas a pessoas, processos ou sistemas devidamente autorizados.

3.3 Integridade

Propriedade que garante que os dados e sistemas permaneçam exatos, completos e não tenham sido alterados de maneira não autorizada.

3.4 Disponibilidade

Garantia de que as informações e serviços estejam acessíveis e utilizáveis pelos usuários autorizados sempre que necessário.

3.5 Autenticidade

Propriedade que assegura que uma entidade, comunicação ou transação é genuína e que sua origem pode ser verificada de forma confiável.

3.6 Responsabilidade (*Accountability*)

Capacidade de rastrear as ações realizadas sobre determinado ativo informacional, associando-as de forma inequívoca a indivíduos ou sistemas, garantindo transparência e auditabilidade.

3.7 Resiliência Cibernética

Capacidade de uma organização de resistir, responder e se recuperar de incidentes cibernéticos, mantendo suas funções críticas e a integridade de suas operações.

3.8 Segurança por Design e por Padrão

Princípio que determina que mecanismos de segurança e proteção de dados sejam incorporados desde a concepção e configuração inicial de sistemas, produtos ou serviços, e não apenas adicionados posteriormente.

3.9 Minimização de Dados

Princípio segundo o qual o tratamento de informações pessoais ou corporativas deve se limitar ao estritamente necessário para a finalidade específica pretendida.

3.10 Sistema de Gestão da Segurança da Informação (SGSI)

Estrutura composta por políticas, processos e controles que permite à organização gerenciar e melhorar continuamente a segurança da informação, conforme definido pela norma ISO/IEC 27001.

3.11 Incidente de Segurança da Informação

Evento que compromete, ou tem potencial de comprometer, a confidencialidade, integridade ou disponibilidade das informações ou sistemas da organização.

3.12 LGPD (Lei Geral de Proteção de Dados Pessoais)

Legislação brasileira (Lei nº 13.709/2018) que regula o tratamento de dados pessoais, impondo obrigações às organizações quanto à coleta, uso, armazenamento e compartilhamento dessas informações.

3.13 Inovação Responsável

Adoção e desenvolvimento de novas tecnologias de forma ética, transparente e segura, considerando seus impactos sobre a privacidade, a segurança e o ambiente digital da organização.

3.14 *Bring Your Own Device* (BYOD)

Em português, “Traga seu Próprio Dispositivo”, refere-se a uma política empresarial que permite aos colaboradores utilizarem seus próprios dispositivos eletrônicos, como smartphones, tablets e notebooks, para realizar suas atividades de trabalho.

4 Princípios

4.1 Princípios gerais

- 4.1.1 Toda força de trabalho da Sentinela Controladoria está sujeita à esta PSI e assume responsabilidade para com a proteção de informações internas e de clientes;
- 4.1.2 A proteção dos ativos informacionais deve basear-se em torno da tríade essencial de Segurança da Informação: confidencialidade, integridade e disponibilidade;
- 4.1.3 A Sentinela Controladoria monitora e controla acessos e o conteúdo de informações e sistemas sustentados em seus ambientes, em conformidade com a legislação brasileira;
- 4.1.4 Deve-se garantir a conformidade com normas de segurança da informação e legislações aplicáveis, fortalecendo a cultura de proteção de dados na organização;
- 4.1.5 A organização deve assumir uma cultura de ética e responsabilidade com o uso, tratamento e compartilhamento de informações.

4.2 Princípios específicos de segurança cibernética

- 4.2.1 A segurança da informação deve ser incorporada desde a concepção (“*by design*”) e por padrão (“*by default*”) em todos os processos, sistemas e serviços desenvolvidos ou adquiridos pela organização;
- 4.2.2 O princípio da minimização de dados deve orientar todas as atividades que envolvam tratamento de informações, limitando-se à coleta e uso estritamente necessários à finalidade pretendida;
- 4.2.3 O acesso às informações, sistemas e recursos tecnológicos da Sentinela Controladoria deve ser concedido com base no princípio do menor privilégio e na necessidade de saber;
- 4.2.4 As informações devem ser classificadas de acordo com seu nível de sensibilidade e importância, garantindo tratamento adequado à sua criticidade;
- 4.2.5 Deve-se garantir a redundância de dados e serviços críticos, incluindo backups e planos de contingência;
- 4.2.6 O uso aceitável de recursos tecnológicos deve observar princípios éticos, legais e de segurança, restringindo o uso a finalidades corporativas.

5 Diretrizes

5.1 Diretrizes de Segurança da Informação

A Sentinela Controladoria estabelece que suas diretrizes sobre segurança da informação se baseiam em normas e legislações oficiais e amplamente confiáveis, sendo elas, especificamente: a segurança da informação; a segurança em recursos humanos; a gestão de ativos; o controle de acesso; a segurança física; o desenvolvimento e manutenção de sistemas; o relacionamento na cadeia de suprimento; a gestão da continuidade do negócio e; a conformidade.

5.2 Diretrizes de Segurança Cibernética

As diretrizes de segurança cibernética da Sentinela Controladoria baseiam-se em normas e legislações oficiais e amplamente confiáveis, sendo elas, especificamente: a garantia dos atributos de confidencialidade, integridade e disponibilidade; a classificação de informações, em qualquer formato, conforme seu nível de sensibilidade e criticidade; a adoção de princípios de segurança desde a concepção de seus projetos; a adoção de mecanismos robustos de autenticação; o acesso a sistemas e dados seguindo o princípio do menor privilégio; a conscientização contínua sobre segurança digital e; o preparo contra ameaças e incidentes de segurança da informação.

6 Responsabilidades

A governança da Segurança da Informação da Sentinela Controladoria é atribuída integralmente ao Time de Tecnologia da Informação, responsável por conduzir, supervisionar e aprimorar todas as ações relacionadas à proteção dos ativos informacionais e à resiliência cibernética da organização, exercendo papel central na tomada de decisões estratégicas e técnico-operacionais.

Compete ao Time de Tecnologia definir e revisar periodicamente os controles de segurança, avaliar riscos e vulnerabilidades, implementar medidas corretivas e preventivas, além de assegurar a conformidade dos processos internos com legislações e normas vigentes. Também lhe cabe o dever de fomentar novas iniciativas de segurança da informação e cibernética, promovendo a inovação responsável, a adoção de tecnologias seguras e a disseminação da cultura de proteção de dados na Sentinela.

Todas as decisões estratégicas referentes à gestão da segurança, ao tratamento de incidentes e à priorização de investimentos em infraestrutura tecnológica deverão ser deliberadas por este time, que atuará como autoridade técnica e gestora da PSI. Sua responsabilidade estende-se à orientação e ao apoio contínuo aos demais setores, garantindo que as diretrizes de segurança sejam compreendidas, aplicadas e mantidas de forma coerente e sustentável em todos os níveis organizacionais.

7 Disposições finais

A presente PSI da Sentinela Controladoria será objeto de revisão anual ou a qualquer tempo em que ocorram mudanças relevantes no ambiente de negócios, conduzida pelo Time de Tecnologia, a fim de assegurar sua constante adequação às mudanças organizacionais, tecnológicas e regulatórias. Essa revisão visa manter a política atualizada diante da evolução das ameaças cibernéticas, das boas práticas de governança da informação e das normas internacionais de referência, como as séries ISO/IEC 27000 e o NIST Cybersecurity Framework.

O cumprimento integral das disposições desta política é obrigatório para toda força de trabalho da Sentinela Controladoria, incluindo diretores, gestores, analistas, estagiários, consultores e prestadores de serviço. O descumprimento, negligência ou violação deliberada de quaisquer de suas diretrizes poderá resultar em sanções disciplinares, aplicadas conforme a gravidade da infração e em conformidade com os regulamentos internos da empresa e com a legislação vigente.

Assim, esta política representa um compromisso institucional com a ética, a segurança e a responsabilidade no tratamento da informação, reafirmando que a proteção dos dados é dever coletivo e condição essencial para a confiança, a continuidade e a excelência dos serviços prestados pela Sentinela Controladoria.

8 Referências

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. NBR ISO/IEC 27000:2023 — Tecnologia da Informação — Técnicas de Segurança — Sistemas de Gestão de Segurança da Informação — Visão Geral e Vocabulário. Rio de Janeiro: ABNT, 2023;

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. NBR ISO/IEC 27001:2023 — Tecnologia da Informação — Técnicas de Segurança — Sistemas de Gestão da Segurança da Informação — Requisitos. Rio de Janeiro: ABNT, 2023;

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. NBR ISO/IEC 27002:2023 — Tecnologia da Informação — Técnicas de Segurança — Controles de Segurança da Informação. Rio de Janeiro: ABNT, 2023;

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. NBR ISO/IEC 27032:2023 — Tecnologia da Informação — Técnicas de Segurança — Diretrizes para Cibersegurança. Rio de Janeiro: ABNT, 2023;

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. NBR ISO/IEC 27701:2019 — Tecnologia da Informação — Técnicas de Segurança — Extensão da ISO/IEC 27001 e 27002 para Gestão da Privacidade — Requisitos e Diretrizes. Rio de Janeiro: ABNT, 2019;

BRASIL. Lei nº 13.709, de 14 de agosto de 2018 — Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União, Brasília, DF, 15 ago. 2018;

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. ISO/IEC 20000-1:2018 — Information Technology — Service Management — Requirements. Geneva: ISO, 2018;

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. ISO/IEC 27035-1:2023 — Information Security Incident Management — Principles of Incident Management. Geneva: ISO, 2023;

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). Framework for Improving Critical Infrastructure Cybersecurity — Version 1.1. Gaithersburg, MD: U.S. Department of Commerce, 2018;

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). Special Publication 800-53, Revision 5 — Security and Privacy Controls for Information Systems and Organizations. Gaithersburg, MD: U.S. Department of Commerce, 2020.